
Informe de Pentesting

Actividad A08 — Hacking Ético

Cliente: INSECUR S.A. — Laboratorio: TryHackMe

Seguridad Aplicada a Sistemas de Información

Licenciatura en Sistemas de Información — Facultad de Informática y Diseño

Docente: Ing. Rodrigo Atilio Elgueta

Ciclo Académico Vigente

Alumno: Carrera Sileci, Martín Tomás — Username TryHackMe: tinchocarrera45

Índice

1. Contexto de la Contratación	2
2. Modelo de Trabajo: Núcleo + Sala de Elección	2
2.1. Nivel 1 — Núcleo obligatorio	2
2.2. Nivel 2 — Sala de elección	2
3. Configuración del Entorno	2
3.1. Requisitos previos	2
3.2. Conexión a la VPN y ajustes técnicos	2
4. Mecanismos de Control de Autenticidad	3
5. Informe Técnico de la Intervención	3
5.1. Datos generales	3
5.2. Pre-pentesting	3
5.3. Hallazgos de Seguridad por Fase	3
5.4. Resumen de Hallazgos	6
6. Protocolo de Contingencia	6
7. Anexos	6

1. Contexto de la Contratación

Carta de Autorización — INSECUR S.A.

Ciente: INSECUR S.A.

Contratista: Estudiante de Seguridad Aplicada a Sistemas de Información (FID-UCH).

Objeto del contrato: La compañía INSECUR S.A., preocupada por los niveles de seguridad de sus sistemas, contrata sus servicios profesionales de **Hacking Ético** para elaborar un plan de seguridad y contingencia.

Alcance autorizado: Únicamente los entornos de laboratorio de la plataforma **TryHackMe** asignados en esta guía. Cualquier acción fuera de este alcance queda estrictamente prohibida y constituye un delito conforme la legislación vigente.

Entregable: Informe profesional de pentesting, incluyendo documentación previa, durante y posterior a la intervención, más un protocolo de contingencia para garantizar la continuidad de negocio.

Modalidad: Individual.

Repositorio de entrega: https://github.com/UCHSeguridad2026/TP_THM.git (branch `carrera-martin`).

2. Modelo de Trabajo: Núcleo + Sala de Elección

2.1. Nivel 1 — Núcleo obligatorio

- **Pentesting Fundamentals:** Metodología y fases del pentesting profesional.
- **Basic Pentesting:** Aplicación práctica integral: enumeración de servicios, explotación y elevación de privilegios.

2.2. Nivel 2 — Sala de elección

Pendiente de selección / En desarrollo: La sala adicional del catálogo curado será incorporada tras la validación del núcleo obligatorio.

3. Configuración del Entorno

3.1. Requisitos previos

1. Cuenta en TryHackMe (username: `tinchocarrera45`).
2. Kali Linux en WSL2 con suite estándar: `nmap`, `gobuster`, `hydra`, `john`, `ssh2john`, `netcat`.
3. Conexión VPN activa mediante OpenVPN.
4. Repositorio institucional clonado en rama de trabajo personal.

3.2. Conexión a la VPN y ajustes técnicos

```
1 sudo openvpn --config ~/Downloads/MartinCarrera.ovpn
2 # Ajuste de MTU aplicado para evitar fragmentación de paquetes en tuneles
   KEX:
3 sudo ip link set dev tun0 mtu 1200
```

4. Mecanismos de Control de Autenticidad

- **Username TryHackMe:** tinchocarrera45 visible en las capturas de la plataforma.
- **Bitácora de comandos:** Registro detallado en `bitacora/basic_pentesting.txt` con datos confidenciales saneados.
- **Evidencias:** Capturas en `evidencias/` organizadas por fases según la nomenclatura establecida.
- **Hash de Flags:** SHA-256 de las credenciales finales documentado en el Anexo C.
- **Rama de control:** Commits y entregables alojados en la branch `carrera-martin`.

5. Informe Técnico de la Intervención

5.1. Datos generales

Campo	Valor
Cliente	INSECUR S.A.
Contratista	Carrera Sileci, Martín Tomás
Username TryHackMe	tinchocarrera45
Branch en GitHub	<code>carrera-martin</code>
Fecha de inicio	07/10/2026
Fecha de cierre	07/10/2026

5.2. Pre-pentesting

Alcance y Reglas de Enfrentamiento (ROE)

Pruebas dirigidas exclusivamente contra los entornos asignados en la sala Basic Pentesting (IPs de sesión: 10.64.148.124 e IP de reinicio 10.65.160.160). Se restringieron los ataques destructivos y denegaciones de servicio.

Metodología

Se implementó una adaptación del estándar **PTES** abordando: Reconocimiento, Escaneo y Enumeración, Explotación (Acceso Inicial) y Post-Explotación (Movimiento Lateral).

5.3. Hallazgos de Seguridad por Fase

Campo	Valor
ID del hallazgo	H-01
Fase	☐ Reconocimiento ☒ Escaneo ☐ Explotación ☐ Post-explotación

Descripción	Enumeración de directorios web expuso la ruta <code>/development</code> , la cual contaba con listado de directorios habilitado y archivos de notas internas (<code>dev.txt</code> , <code>j.txt</code>) que revelaban usuarios y políticas débiles.
Componente	Servidor Apache HTTP (puerto 80)
Categoría	CWE-548: Exposure of Information Through Directory Listing
CVSS estimado	☒ Bajo ☐ Medio ☐ Alto ☐ Crítico
Evidencia	<code>evidencias/escaneo/escaneo_H-01.png</code>
Herramienta	Gobuster
Impacto CIA	☒ Confidencialidad ☐ Integridad ☐ Disponibilidad
Salvaguarda	Deshabilitar la directiva <code>Indexes</code> en Apache y eliminar archivos de testing en servidores productivos.
Riesgo residual	☒ Bajo ☐ Medio ☐ Alto
Campo	Valor
ID del hallazgo	H-02
Fase	☐ Reconocimiento ☐ Escaneo ☒ Explotación ☐ Post-explotación
Descripción	Obtención de acceso SSH inicial contra la cuenta <code>jan</code> mediante ataque de diccionario/fuerza bruta (<code>jan:armando</code>), debido al uso de claves predecibles sin mecanismos de bloqueo de intentos.
Componente	Servicio OpenSSH (puerto 22)
Categoría	CWE-521: Weak Password Requirements
CVSS estimado	☐ Bajo ☐ Medio ☒ Alto ☐ Crítico
Evidencia	<code>evidencias/explotacion/explotacion_H-02.png</code>
Herramienta	Hydra
Impacto CIA	☒ Confidencialidad ☒ Integridad ☐ Disponibilidad
Salvaguarda	Exigir autenticación obligatoria por llave pública, deshabilitar autenticación por contraseña e implementar Fail2ban.
Riesgo residual	☒ Bajo ☐ Medio ☐ Alto
Campo	Valor
ID del hallazgo	H-03

Fase	☐ Reconocimiento ☐ Escaneo ☐ Explotación ☒ Post-explotación
Descripción	Asignación incorrecta de permisos sobre el directorio personal y SSH del usuario kay , permitiendo al usuario jan leer y extraer la clave privada protegida id_rsa .
Componente	Sistema de archivos (/home/kay/.ssh)
Categoría	CWE-732: Incorrect Permission Assignment for Critical Resource
CVSS estimado	☐ Bajo ☐ Medio ☒ Alto ☐ Crítico
Evidencia	evidencias/post/post_H-03_id_rsa.png
Herramienta	Inspección manual de permisos (ls -la)
Impacto CIA	☒ Confidencialidad ☒ Integridad ☐ Disponibilidad
Salvaguarda	Aplicar permisos estrictos de acceso: chmod 700 ~/.ssh y chmod 600 ~/.ssh/id_rsa .
Riesgo residual	☒ Bajo ☐ Medio ☐ Alto
Campo	Valor
ID del hallazgo	H-04
Fase	☐ Reconocimiento ☐ Escaneo ☐ Explotación ☒ Post-explotación
Descripción	Passphrase débil en la clave privada de kay descifrada offline (beeswax), logrando movimiento lateral e identificación de credenciales sin cifrar en el archivo pass.bak .
Componente	/home/kay/pass.bak
Categoría	CWE-256: Plaintext Storage of a Password
CVSS estimado	☐ Bajo ☐ Medio ☒ Alto ☐ Crítico
Evidencia	evidencias/post/post_H-04_john.png, evidencias/post/post_H-04_pass.bak.png
Herramienta	ssh2john, John the Ripper
Impacto CIA	☒ Confidencialidad ☐ Integridad ☐ Disponibilidad
Salvaguarda	Exigir frases de paso de alta entropía y prohibir el resguardo de credenciales en texto plano dentro del sistema de archivos.
Riesgo residual	☒ Bajo ☐ Medio ☐ Alto

5.4. Resumen de Hallazgos

Severidad	Cantidad	ID de hallazgos
Crítico	0	—
Alto	3	H-02, H-03, H-04
Medio	0	—
Bajo	1	H-01
Total	4	H-01 a H-04

6. Protocolo de Contingencia

Escenario de contingencia y plan de respuesta

El ataque de fuerza bruta SSH saturó los hilos del demonio OpenSSH durante la auditoría, provocando caídas de socket e indisponibilidad temporal del puerto 22. Ante incidentes de esta índole en sistemas productivos, el protocolo dicta:

1. **Contención:** Aplicación de reglas de firewall perimetral para restringir intentos concurrentes por origen.
2. **Recuperación:** Reinicio supervisado del servicio SSH y ajuste de `MaxStartups` en `sshd.config`.
3. **Post-mortem:** Integración de agentes activos de mitigación de fuerza bruta.

7. Anexos

Anexo A — Bitácora de Comandos

Archivo disponible en el repositorio: `bitacora/basic_pentesting.txt`.

Anexo B — Evidencias Gráficas

Archivos almacenados en la estructura `evidencias/`:

- `evidencias/reconocimiento/reconocimiento_fundamentals.completado.png`
- `evidencias/escaneo/escaneo_H-01.png`
- `evidencias/explotacion/explotacion_H-02.png`
- `evidencias/post/post_H-03_id_rsa.png`
- `evidencias/post/post_H-04_john.png`
- `evidencias/post/post_H-04_ssh_key.png`
- `evidencias/post/post_H-04_pass_bak.png`
- `evidencias/post/post_basicpentesting_completado.png`

Anexo C — Hashes de Verificación (SHA-256)

```
1 # Formato: identificador sha256_hash
2 BP-cred    3
   ffd53ec80858f9ddcd75d69102724ab1bc1020855fff924227f618c4bfccf57
```

BP-cred: Hash correspondiente a la credencial localizada en `pass.bak`.

Anexo D — Declaración Ética

Declaro que todas las actividades se realizaron dentro del alcance autorizado, en entornos controlados y con fines exclusivamente académicos.

Firma: Martín Tomás Carrera Sileci

Fecha: 7 de octubre de 2026